

Mini-Rapport d'Analyse Statique

MobSF – OWASP UnCrackable Level 1

Auteur	Chagdaly Hiba
Date	03 Mai 2026
Cours	Securite des applications mobiles
Lab	Lab 06 – MobSF Static Analysis
Outil	MobSF v4.5.0 (Docker)
APK	OWASP UnCrackable-Level1.apk

*Ce rapport est realise dans un cadre pedagogique.
L'application analysee est volontairement vulnerable (OWASP MASTG).*

Informations generales

Propriete	Valeur
Package	owasp.mstg.uncrackable1
Version	1.0
Target SDK	28 (Android 9)
Min SDK	19 (Android 4.4)
SHA-256	1da8bf57d266109f9a07c01bf7111a1975ce01f190b9d914bcd3ae3dbef96f21
Score securite	55/100 – MEDIUM RISK – Grade B
Trackers	0/432

Table 1: Informations de l'APK analyse

```

mobexler@Mobexler ~/apk_analysis/2026-05-02
└─ cat apk_hash.txt
1da8bf57d266109f9a07c01bf7111a1975ce01f190b9d914bcd3ae3dbef96f21  UnCrackable-Level1.apk
mobexler@Mobexler ~/apk_analysis/2026-05-02
└─

```

Figure 1: Hash SHA-256 de l'APK

```

[MOBSF]
[MOBSF]
[MOBSF]

[INFO] 03/May/2026 11:05:24 - Author: Ajin Abraham | opensecurity.in
[INFO] 03/May/2026 11:05:24 - Mobile Security Framework v4.5.0
REST API Key: 3c82e2e025ea20aaef1993bdd439ce0be73dfa6d781c34dc8813dc94e7ae1d71
Default Credentials: mobsf/mobsf
[INFO] 03/May/2026 11:05:24 - OS Environment: Linux (debian 12 bookworm) Linux-4.19.0-21-amd64-x86_64-with-
glibc2.36
[INFO] 03/May/2026 11:05:24 - Python Version: 3.13.12
[INFO] 03/May/2026 11:05:24 - CPU Cores: 2, Threads: 2, RAM: 3.85 GB
[INFO] 03/May/2026 11:05:24 - MobSF Basic Environment Check
Roles Created Successfully!
[INFO] 03/May/2026 11:05:25 - Checking for Update.
[INFO] 03/May/2026 11:05:25 - No updates available.
[2026-05-03 11:05:26 +0000] [1] [INFO] Starting gunicorn 25.1.0
[2026-05-03 11:05:26 +0000] [1] [INFO] Listening at: http://0.0.0.0:8000 (1)
[2026-05-03 11:05:26 +0000] [1] [INFO] Using worker: gthread
[2026-05-03 11:05:26 +0000] [1] [INFO] Control socket listening at /home/mobsf/Mobile-Security-Framework-Mo
bSF/gunicorn.ctl
[2026-05-03 11:05:26 +0000] [106] [INFO] Booting worker with pid: 106
[INFO] 03/May/2026 11:05:28 - Loading User config from: /home/mobsf/.MobSF/config.py

```

Figure 2: MobSF v4.5.0 démarre

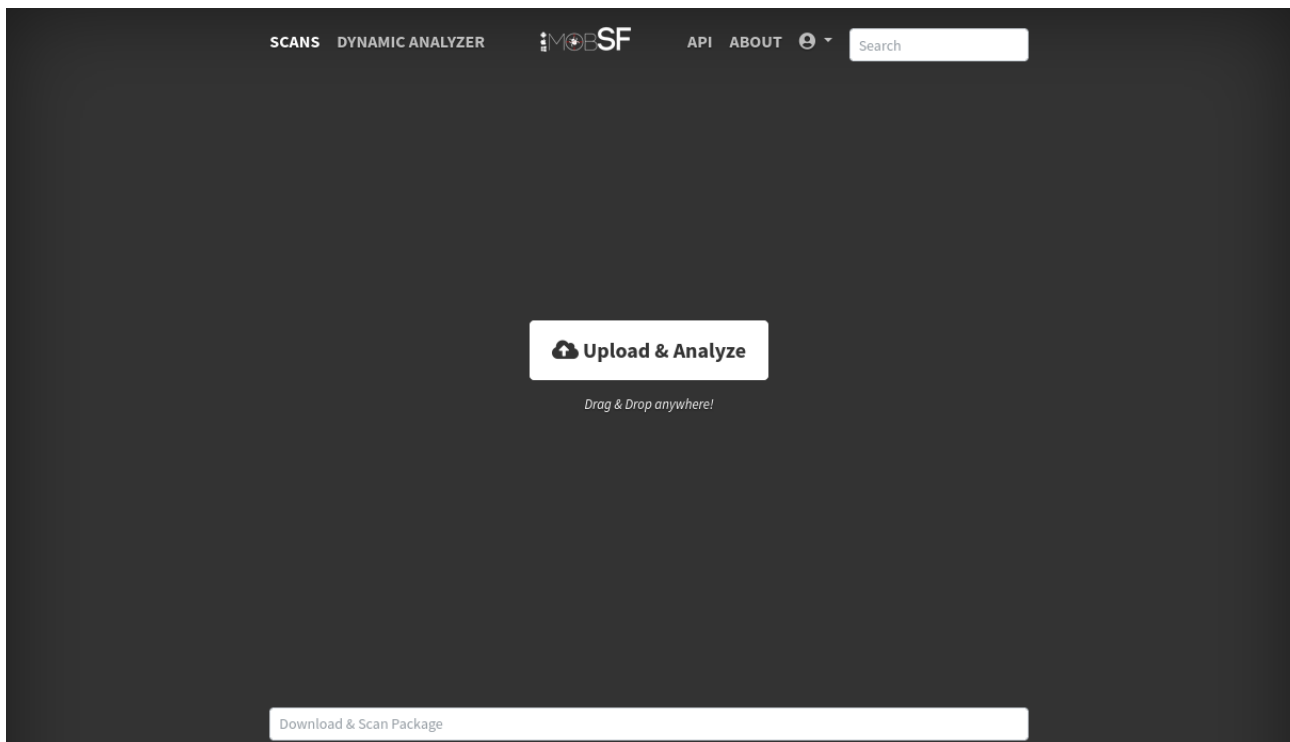


Figure 3: Interface MobSF

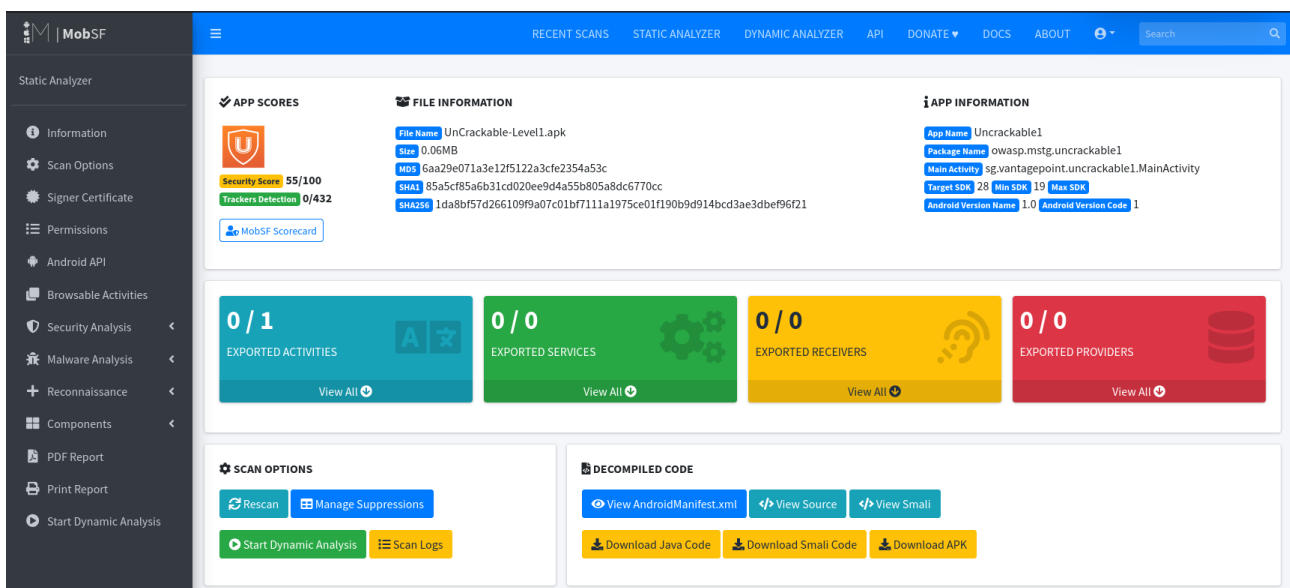


Figure 4: Score de securite global – 55/100 (Medium Risk)

Permissions et composants exposes

2.1 Permissions declarees

Aucune permission Android n'est declaree dans le manifeste.

2.2 Composants exportes

Type	Details	Risque
Exported Activities	0/1 (MainActivity implicitement exportee)	[MOYENNE]
Exported Services	0/0	—
Exported Receivers	0/0	—
Exported Providers	0/0	—

Table 2: Composants exportes

The screenshot shows the MobSF Static Analyzer interface. The left sidebar contains navigation options: Information, Scan Options, Signer Certificate, Permissions, Android API, Browsable Activities, Security Analysis, Malware Analysis, Reconnaissance, Components, PDF Report, Print Report, and Start Dynamic Analysis. The main content area is divided into two sections:

SIGNER CERTIFICATE

Binary is signed
v1 signature: True
v2 signature: True
v3 signature: False
v4 signature: False
X.509 Subject: C=NL, L=Amsterdam, O=OWASP, OU=OMTG, CN=Jeroen Willemsen
Signature Algorithm: rsassa_pkcs1v15
Valid From: 2018-08-27 21:01:00+00:00
Valid To: 2043-08-21 21:01:00+00:00
Issuer: C=NL, L=Amsterdam, O=OWASP, OU=OMTG, CN=Jeroen Willemsen
Serial Number: 0x71861047
Hash Algorithm: sha256
md5: 1001e3c49001fcc5f079325278df94ca
sha1: 13e49a39e628817cbbde2881f4646c2a0b22adb2
sha256: cbe68ab87d64341c3fc78119dc1229e8aa86f93fdb2c33aa61252fd491485b1d
sha512: 30ce347be73baca32bd740262d54007ead7ac524f4b62dfc13019ca2b4a0b08820f2ef8da9e9c77d6bdc1456edfbed1500069dd178b7e0432ada053963db1cd
PublicKey Algorithm: rsa
Bit Size: 2048
Fingerprint: e3111e7eef44e1fff8763dfb4a27833d9ec4fc9deb72cab052ac0194ca25bfd0
Found 1 unique certificates

APPLICATION PERMISSIONS

Search:

PERMISSION	STATUS	INFO	DESCRIPTION	CODE MAPPINGS
No data available in table				

Figure 5: Certificat de signature et permissions

Constats de securite

Constat 1 – minSdk=19 (Android 4.4 vulnerable) [ELEVÉE]

Localisation : AndroidManifest.xml

Observation : L'application peut être installée sur Android 4.4 qui contient de nombreuses vulnérabilités non corrigées par Google.

Impact : Les appareils sous Android < 10 ne reçoivent plus de mises à jour de sécurité de Google.

Remediation : Définir `minSdkVersion >= 29` (Android 10) pour garantir un niveau de sécurité raisonnable.

Constat 2 – Algorithme AES/ECB non sécurisé [ELEVÉE]

Localisation : sg/vantagepoint/a/a.java

Reference MASVS : MSTG-CRYPTO-2 / CWE-327

Observation : MobSF détecte l'utilisation de AES en mode ECB :

```
Cipher.getInstance("AES") // retourne AES/ECB par défaut
```

The screenshot shows the MobSF interface with the 'CODE ANALYSIS' tab selected. The left sidebar lists various analysis options, with 'Code Analysis' highlighted. The main area displays a table of detected issues. At the top, there are filters for severity: HIGH (1), WARNING (1), INFO (1), SECURE (1), and SUPPRESSED (0). A search bar is also present.

NO	ISSUE	SEVERITY	STANDARDS	FILES	OPTIONS
1	This App may request root (Super User) privileges.	warning	CWE: CWE-250: Execution with Unnecessary Privileges OWASP MASVS: MSTG-RESILIENCE-1	sg/vantagepoint/a/c.java	[icon]
2	This App may have root detection capabilities.	secure	OWASP MASVS: MSTG-RESILIENCE-1	sg/vantagepoint/a/c.java	[icon]
3	Calling Cipher.getInstance("AES") will return AES ECB mode by default. ECB mode is known to be weak as it results in the same ciphertext for identical blocks of plaintext.	high	CWE: CWE-327: Use of a Broken or Risky Cryptographic Algorithm OWASP Top 10: M5: Insufficient Cryptography OWASP MASVS: MSTG-CRYPTO-2	sg/vantagepoint/a/a.java	[icon]
4	The App logs information. Sensitive information should never be logged.	info	CWE: CWE-532: Insertion of Sensitive Information into Log File OWASP MASVS: MSTG-STORAGE-3	sg/vantagepoint/uncrackable1/a.java	[icon]

Showing 1 to 4 of 4 entries

Previous 1 Next

Figure 6: Code Analysis – 4 vulnaribilites detectees

Impact : Le mode ECB produit des blocs chiffres identiques pour des blocs de texte clair identiques – vulnerable aux attaques par analyse de motifs.

Remediation : Remplacer AES/ECB par AES/GCM avec IV aleatoire.

Constat 3 – Secrets hardcodes dans le binaire [ELEVÉE]

Localisation : Strings du code

Reference MASVS : MSTG-STORAGE-3 / CWE-532

Observation : MobSF identifie dans les strings du code :

```
Cle AES : 8d127684cbc37c17616d806cf50473cc
Secret chiffre : 5UJiFctbmgbDoLXmpL12mkno8HT4Lv8dlat8FxR2G0c=
Algorithme : AES/ECB/PKCS7Padding
```

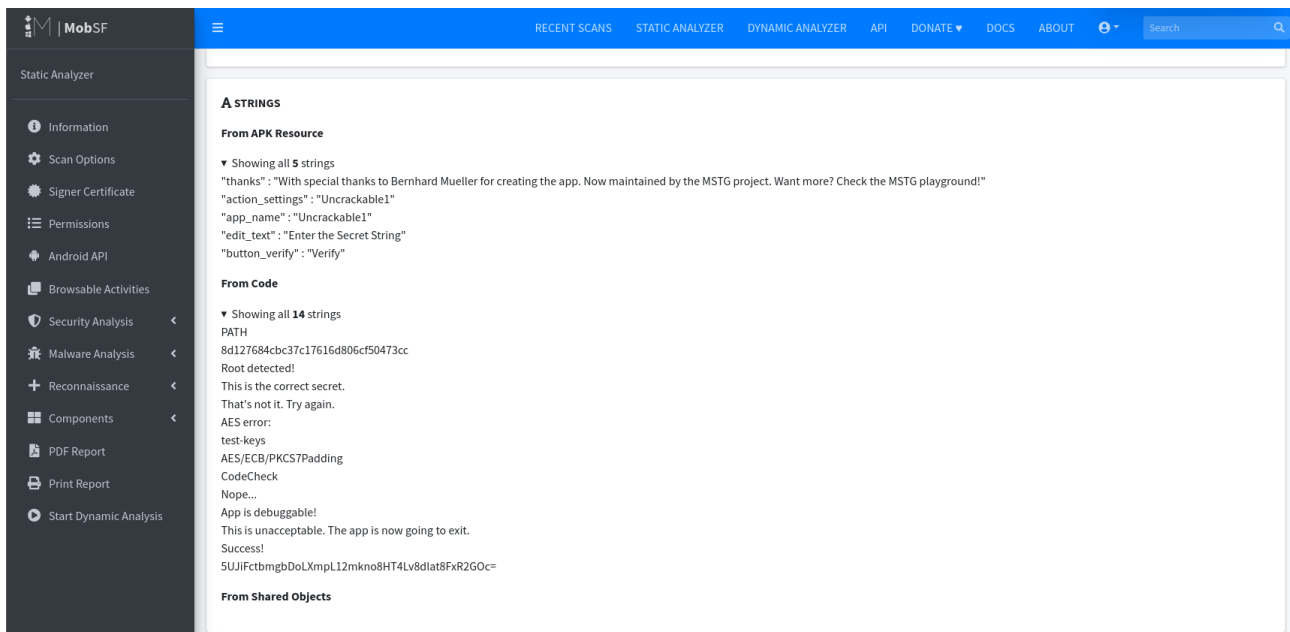


Figure 7: Strings sensibles detectes par MobSF

Impact : Le secret peut etre retrouve par simple analyse statique sans executer l'application.

Remediation : Ne jamais stocker de secrets dans le code. Utiliser Android Keystore pour la gestion des clees cryptographiques.

Constat 4 – android:allowBackup=true [MOYENNE]

Localisation : AndroidManifest.xml

Observation : MobSF signale que la sauvegarde ADB est activee.

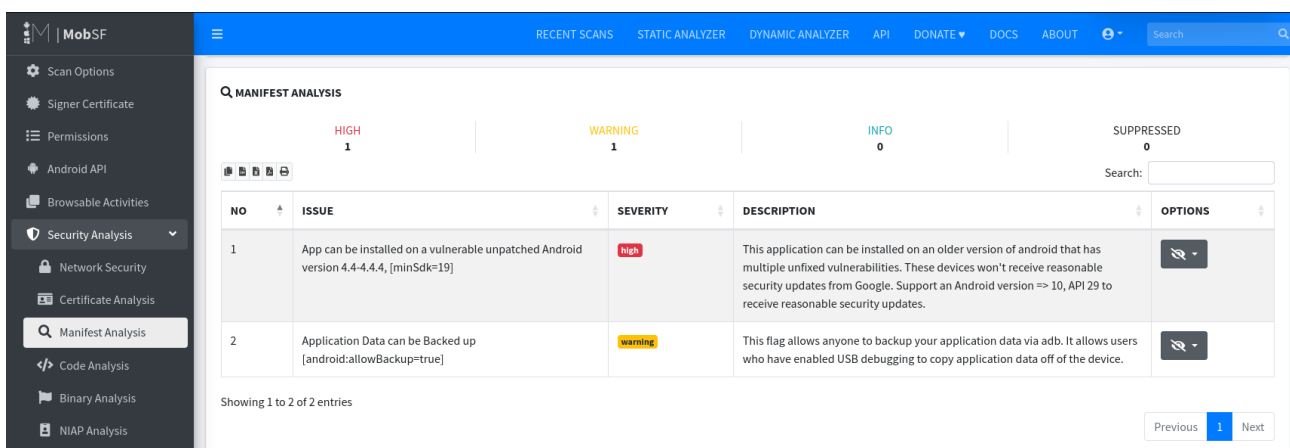


Figure 8: Manifest Analysis – allowBackup et minSdk

Impact : Extraction des donnees via adb backup possible sur tout appareil avec USB debugging active.

Remediation : Definir android:allowBackup="false".

Constat 5 – Vulnerabilite Janus (signature v1) [MOYENNE]

Localisation : Certificat de signature

Observation : L'APK est signe uniquement avec le schema v1.

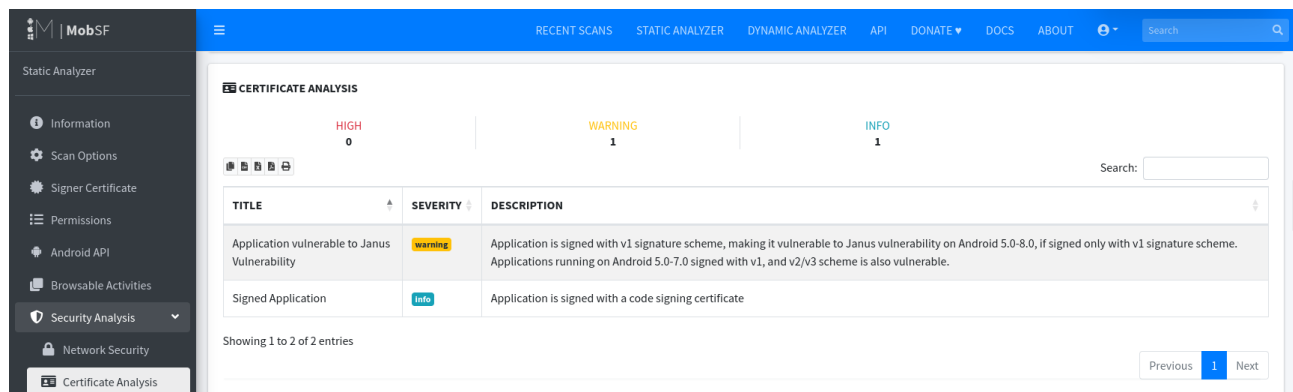


Figure 9: Certificate Analysis – Janus vulnerability

Impact : Sur Android 5.0-8.0, la vulnerabilite Janus permet d'injecter du code malveillant sans invalider la signature.

Remediation : Signer avec les schemas v2 et v3 en plus du v1.

Comparaison MobSF vs JADX GUI

Critere	MobSF	JADX GUI
Type d'analyse	Automatisee	Manuelle
Score securite	Oui (55/100)	Non
References MASVS	Automatiques	Manuelles
Detection secrets	Automatique	Recherche manuelle
Profondeur	Moyenne	Elevee
Faux positifs	Possibles	Controles
Rapport PDF	Genere automatiquement	Manuel

Table 3: Comparaison des outils d'analyse statique

Synthese des risques

Constat	Severite	MASVS	Remediation
minSdk=19 vulnerable	[ELEVEE]	–	minSdk >= 29
AES/ECB non securise	[ELEVEE]	MSTG-CRYPTO-2	AES/GCM
Secrets hardcodes	[ELEVEE]	MSTG-STORAGE-3	Android Keystore
allowBackup=true	[MOYENNE]	–	allowBackup=false
Janus (signature v1)	[MOYENNE]	–	Schema v2/v3

Table 4: Tableau de synthese



Figure 10: Rapport PDF MobSF – Score 55/100 Grade B

Conclusion

L'analyse MobSF confirme les vulnérabilités identifiées manuellement dans le Lab 04, avec en plus la vulnérabilité Janus et le problème de minSdk. Le score de **55/100 (Grade B)** reflète un niveau de risque moyen pour une application de challenge pédagogique. En production, ces vulnérabilités auraient un impact critique.